

BETRIEBSHANDBUCH

ZSD – Zentrale Sicherheitsdienste

Identitätsverwaltung, Public-Key-Infrastruktur und Secret-Management
für alle Verfahren des Bundesamtes

Anwendung	ZSD – Zentrale Sicherheitsdienste (IAM, PKI, Vault)
CI-Nummer	CI-PLT-0007
Verantwortlicher	Kai Ostermann (Bereich IT-S 1, Durchwahl 1315)
Vertretung	Sabine Wollmer (Durchwahl 1180)
Fachseite	Bereich IT-S 1 – Informationssicherheit und Basisdienste
Dokument	BHB-PLT-0007, Version 2.3
Stand	22. Juli 2026
Klassifizierung	intern · Testdokument – fiktive Daten

Herausgeber: Bundesamt für Verfahrensdienste (BAVD), Bereich IT-S 1 – Informationssicherheit und Basisdienste · Interne Dokumentation · Weitergabe nur an berechnigte Stellen

Inhaltsverzeichnis

1 Dokumentinformation

- 1.1 Zweck, Zielgruppe, Geltungsbereich
- 1.2 Änderungshistorie
- 1.3 Verwandte Dokumente

2 Kurzbeschreibung und Abgrenzung

- 2.1 Die drei Dienste
- 2.2 Abgrenzung
- 2.3 Kennzahlen des laufenden Betriebs

3 Systemüberblick

- 3.1 Architektur
- 3.2 Komponenten und Instanzen
- 3.3 Vernetzung und Ports

4 Konsumenten und Verknüpfungen

- VPP Portal (BHB-VRF-0207)
- Mars Dokumentendienste (BHB-VRF-0118)
- Event-System 2.0 (BHB-PLT-0042)
- CaaS-Plattform (BHB-PLT-0001)
- Überwachung des VPP (BHB-VRF-0207)

5 Betrieb

- 5.1 Servicezeiten und Wartungsfenster
- 5.2 Zugänge und Rollen
- 5.3 Standardabläufe
 - 5.3.1 Keycloak rollierend neu starten (SOP-ZSD-02)
 - 5.3.2 Client-Secret rotieren (SOP-ZSD-03)
 - 5.3.3 Vault entsiegeln (SOP-ZSD-05)
- 5.4 Zertifikatslebenszyklus
- 5.5 Standard Operating Procedures

6 Abhängigkeiten und Auswirkungen

- 6.1 Überblick
- 6.2 Auswirkungsmatrix
- 6.3 Zirkuläre Abhängigkeit und ihre Auflösung

7 Troubleshooting

- 7.1 Meldewege und erste Prüfungen
- 7.2 Dokumentierte Störungsbilder
 - 7.2.1 ACME-Anträge werden von der Firewall verworfen
 - 7.2.2 Client-Secret ohne Abstimmung rotiert
 - 7.2.3 Truststore nach CA-Wechsel zu spät verteilt
 - 7.2.4 Vault nach Knotenwartung versiegelt
- 7.3 Incident-Liste

8 Monitoring, Sicherung und Notfall

- 8.1 Metriken, Schwellwerte und Alarme
- 8.2 Sicherung und Wiederherstellung

8.3 Break-Glass

9 Rollen, Verantwortlichkeiten und Eskalation

9.1 Rollen und Erreichbarkeit

9.2 Eskalation

9.3 Halter der Unseal-Schlüsselanteile

10 Glossar und verwandte Dokumente

10.1 Glossar

10.2 Weiterführende Dokumente und Seiten

1 Dokumentinformation

1.1 Zweck, Zielgruppe, Geltungsbereich

Dieses Handbuch beschreibt den Betrieb der Zentralen Sicherheitsdienste (ZSD) des Bundesamtes für Verfahrensdienste (BAVD): Identitätsverwaltung mit Keycloak, interne Public-Key-Infrastruktur mit der BAVD Issuing CA 3 und Secret-Management mit Vault. Alle drei sind Basisdienste ohne eigene Fachaufgabe; jede Kopplung ist deshalb aus Sicht des Erbringers *und* des Konsumenten beschrieben. Zweiter Zweck ist die Beantwortung der Frage, die bei zentralen Diensten am häufigsten gestellt wird: „Wenn ich diesen Dienst neu starte oder er fällt aus — wer ist betroffen, wie hoch ist das Risiko, mit wem muss ich reden?“ Die Antwort steht in Kapitel 5.3 (Vorgehen), Kapitel 4 (Konsumenten und Ansprechpartner) und Kapitel 6 (Auswirkungen).

Zielgruppe sind der ZSD-Betrieb im Bereich IT-S 1, der Systembetrieb der angebundenen Verfahren, der First- und Second-Level-Support, der Netzbetrieb und der CaaS-Plattformbetrieb als unmittelbare Nachbarn sowie die Informationssicherheit für Nachweise zu Rollen, Sperrungen und Break-Glass. Geltungsbereich ist die Produktion einschließlich des föderierten Active Directory; Test- und Entwicklungsstände (Realm `bavd-test`, BAVD Test CA 1, Namespace `vault-system-test`) folgen denselben Abläufen ohne Rufbereitschaft und ohne Vier-Augen-Prinzip.

1.2 Änderungshistorie

Tabelle 1 führt die Änderungen seit Version 1.8; sie sind überwiegend Folge dokumentierter Störungen (Kapitel 7).

Tabelle 1: Änderungshistorie

Version	Datum	Autor	Änderung
1.8	12.09.2025	Kai Ostermann	Regel FW-ZSD-004 dauerhaft freigeschaltet, synthetische ACME-Prüfung aufgenommen (Folge aus ZSDSUP-0119)
2.0	03.02.2026	Sabine Wollmer	Kapitel 5.4 neu gefasst, Abbildung 2 ergänzt, Sperrfrist auf 4 Stunden festgelegt
2.1	25.05.2026	Kai Ostermann	SOP-ZSD-03 um Abstimmungspflicht und Übergabepfad, SOP-ZSD-04 um die Bestätigungsliste erweitert (Folge aus ZSDSUP-0208 und ZSDSUP-0214)
2.2	10.07.2026	Marcel Ebert	Vault-Unseal, Alarm VaultSealed und Break-Glass überarbeitet, Ankündigungspflicht für Knotenwartungen (Folge aus ZSDSUP-0247)
2.3	22.07.2026	Kai Ostermann	Konsumentenmatrix (Kapitel 4) und Auswirkungsmatrix (Kapitel 6) aufgenommen, Abbildungen 1 und 3 ergänzt, Verweise auf BHB-PLT-0001 eingearbeitet

1.3 Verwandte Dokumente

Tabelle 2 nennt die Handbücher der vier Konsumenten und die übergreifenden Vorgaben. Jede Kopplung ist in beiden Dokumenten beschrieben; bei Abweichungen gelten Ports und Hostnamen dieses Handbuchs, Verfahrensabläufe das Handbuch des Verfahrens.

Tabelle 2: Verwandte Dokumente und Berührungspunkt

Kennung	Dokument	Stand	Berührungspunkt
BHB-VRF-0207	Betriebshandbuch VPP – Verfahrensportal Prüfprozesse, V 6.2	17.07.2026	Client vpp-portal, manuelle Zertifikate (SOP-VPP-05), kv/vpp/prod/*
BHB-VRF-0118	Betriebshandbuch Mars Dokumentendienste, V 4.1	21.07.2026	Client dd-gateway, gemischtes Verfahren (SOP-DD-05), kv/dd/*
BHB-PLT-0042	Betriebshandbuch Event-System 2.0, V 2.3	19.05.2026	Client es-grafana, ACME über cert-manager, kv/event-system/*

Kennung	Dokument	Stand	Berührungspunkt
BHB-PLT-0001	Betriebshandbuch CaaS – Container-Plattform als Dienst, V 3.6	20.07.2026	Trägerplattform von Vault, Client caas-console, Kaltstart SOP-CAAS-06
NET-ZK-004	Zonenkonzept Verfahrensnetz	04/2026	Zonendefinitionen und erlaubte Übergänge, Grundlage der Portmatrix (Kapitel 3.3)
SBF-ITS-2025	Schutzbedarfsfeststellung Basisdienste Bereich IT-S	11/2025	Vertraulichkeit hoch, Integrität hoch, Verfügbarkeit hoch
NFH-ITS-1.4	Notfallhandbuch Bereich IT-S	06/2026	Meldewege, Krisenstab, Break-Glass (Kapitel 8.3)

Hinweis zur Dokumentenlenkung

Gültige Fassung: <https://confluence.bavd.intern/display/ZSD/Betriebshandbuch>. Ausdrücke sind unkontrollierte Kopien. Alle genannten Personen, Hostnamen, IP-Adressen, Vorgangs- und Vertragsnummern sind Beispieldaten einer Erprobungsumgebung.

2 Kurzbeschreibung und Abgrenzung

2.1 Die drei Dienste

IAM — Keycloak 24.0, Realm bavd-intern

Anmeldung aller Oberflächen und Schnittstellen über OpenID Connect. Identitäten und Gruppen stammen per Benutzerföderation aus dem Active Directory; Keycloak führt keine eigenen Personenkonten, Rollen entstehen ausschließlich aus AD-Gruppen.

PKI — BAVD Issuing CA 3

Ausstellung, Erneuerung und Sperrung aller internen Server- und Clientzertifikate. Anträge über das RA-Portal und das Jira-Projekt PKI oder automatisiert über ACME; Sperrinformation über CRL und OCSP.

Vault — Secret-Management

Zentrale Ablage aller Kennwörter, Zugangsschlüssel, Passphrasen und Keystores. Container authentisieren sich über die Kubernetes-Authentifizierung ihres ServiceAccounts, Automatisierung auf virtuellen Maschinen über AppRole. Auf den Servern der Verfahren stehen keine Kennwörter in Konfigurationsdateien.

Verantwortlich für alle drei Dienste ist der Bereich IT-S 1. Das Active Directory betreibt technisch das ZRB, fachlich führt es der IAM-Betrieb (Kai Ostermann), weil daraus die Rollen entstehen.

2.2 Abgrenzung

Nicht Bestandteil der Zentralen Sicherheitsdienste sind:

- **Fachliche Berechtigungen.** Das IAM liefert Identität und Gruppenmitgliedschaft; welche Rolle welche Handlung erlaubt, entscheidet das Verfahren.
- **Pflege der Gruppenmitgliedschaften.** Anträge laufen über den Benutzerservice und die Fachseite, nicht über den ZSD-Betrieb.
- **Betrieb der Container-Plattform.** Vault ist Mandant im Namespace vault-system auf ocp-prod; Cluster, Knoten, Speicher und Ingress verantwortet der CaaS-Plattformbetrieb (BHB-PLT-0001).
- **Verteilung der Zertifikate in die Systeme.** Der ZSD stellt aus und veröffentlicht die Sperrinformation; Import, Truststore-Pflege und Neustart liegen beim Konsumenten (Kapitel 5.4).
- **Externe Zertifikate** für öffentlich erreichbare Endpunkte und die Schlüsselverwaltung für Datenbank- und Bandverschlüsselung.

2.3 Kennzahlen des laufenden Betriebs

Tabelle 3 gibt den Betriebsumfang zum 30.06.2026 wieder (Quelle: Grafana-Ordner „ZSD“, Wochenbericht der PKI).

Tabelle 3: Betriebskennzahlen der Produktion (Stand 30.06.2026)

Kennzahl	Wert	Anmerkung
Clients im Realm bavd-intern	38	16 produktiv, 22 in Test und Abnahme
Föderierte Benutzerkonten	4 180	keine lokalen Personenkonten
Anmeldungen je Werktag	ca. 14 200	Spitze 2 600 zwischen 07:00 und 08:00; Fehlerquote 1,3 % (Schwellwert 5 %)
Gleichzeitige Sitzungen (Spitze)	1 450	im Infinispan-Cluster, zwei Eigentümer je Sitzung
Gültige Zertifikate	1 842	davon 1 190 automatisiert über ACME erneuert

Kennzahl	Wert	Anmerkung
Ausstellungen 1. Halbjahr 2026	612	davon 47 manuell über RA-Portal und Projekt PKI; 9 Sperrungen
OCSP-Anfragen je Tag	ca. 96 000	Antwortzeit p95 unter 40 ms
Vault-Pfade (KV v2)	152	11 Mandantenbereiche, rund 2 100 Lesezugriffe je Tag
Verfügbarkeit Apr 2025 – Mär 2026	IAM 99,98 % · PKI 99,9 % · Vault 99,95 %	RTO IAM 1 h, RPO 15 min; Token-Ausstellung p95 180 ms

Gut zu wissen

Ein rollierender IAM-Neustart bleibt für die Konsumenten unsichtbar: Sitzungen liegen verteilt im Infinispan-Cluster, und ein ausgestelltes Token prüft der Konsument selbst mit dem öffentlichen Realm-Schlüssel — ohne Rückfrage beim IAM. Erst ein Vollaussfall wirkt, und dann nur auf neue Anmeldungen.

3 Systemüberblick

3.1 Architektur

Abbildung 1 zeigt die drei Dienste mit Hosts und Ports und alle Konsumenten mit Client, Zertifikatsverfahren, Vault-Pfad und Betriebshandbuch — die Übersichtskarte für alle Abhängigkeitsfragen. IAM und PKI laufen bewusst auf virtuellen Maschinen im Hausnetz Süd (ZONE-APP-SD, 10.20.0.0/16), nur Vault als Mandant auf ocp-prod. Diese Trennung hält Anmeldung und Ausstellung verfügbar, während die Plattform anläuft (Kapitel 6.3). Jede Schicht ist zweifach ausgelegt; iam-p01 und pki-p01 stehen in getrennten Brandabschnitten des Hausnetzes Süd (SD-A und SD-B), der dritte IAM-Knoten in SD-A.

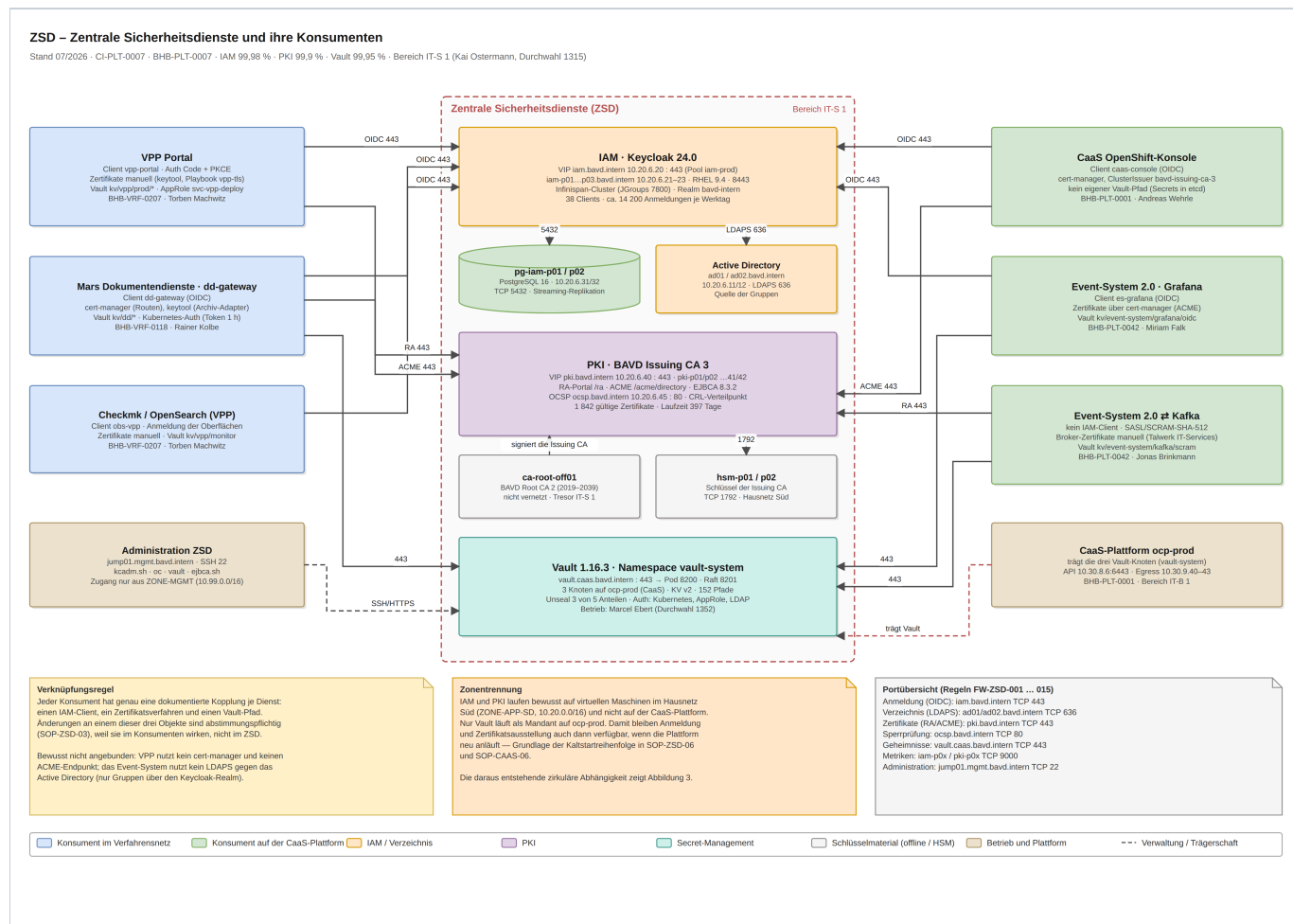


Abbildung 1: Zentrale Sicherheitsdienste und ihre Konsumenten — IAM, Verzeichnis, PKI und Vault in der Mitte, die vier Verfahren und die Plattform ringsum, jede Verbindung mit Protokoll und Port.

3.2 Komponenten und Instanzen

Tabelle 4 nennt alle Instanzen der Produktion mit Adresse, Port, Version und Besonderheit.

Tabelle 4: Instanzen der Produktionsumgebung

Dienst	Host / Objekt	Adresse	Port	Version	Bemerkung
IAM (VIP)	iam.bavd.intern	10.20.6.20	443	F5 BIG-IP 17.1	Pool iam-prod, Monitor GET /health/ready (5 s)
IAM Knoten	iam-p01...p03.bavd.intern	10.20.6.21-23	8443, 9000	Keycloak 24.0, RHEL 9.4	OpenJDK 21, Heap 4 GB; 9000 Metriken, 7800

Dienst	Host / Objekt	Adresse	Port	Version	Bemerkung
			7800		Infinispan/JGroups
IAM Datenbank	pg-iam-p01 / p02.bavd.intern	10.20.6.31/32	5432	PostgreSQL 16	Datenbanken keycloak und ejbca, Streaming-Replikation
Verzeichnis	ad01 / ad02.bavd.intern	10.20.6.11/12	636	Active Directory	LDAPS, Benutzerföderation, Betrieb durch ZRB
PKI (VIP)	pki.bavd.intern	10.20.6.40	443	F5 BIG-IP 17.1	RA-Portal /ra, ACME /acme/directory
Issuing CA	pki-p01 / p02.bavd.intern	10.20.6.41/42	443, 8443	EJBCA 8.3.2, RHEL 9.4	BAVD Issuing CA 3 (2023–2033); 8443 nur Verwaltung
Sperddienst	ocsp.bavd.intern	10.20.6.45	80	EJBCA OCSP-Responder	CRL-Verteilpunkt unter demselben Namen; Antworten signiert, daher ohne TLS
Root-CA	ca-root-off01	nicht vernetzt	—	BAVD Root CA 2 (2019–2039)	Datenträger und Anteile im Tresor Bereich IT-S 1
Schlüsselspeicher	hsm-p01 / p02	10.20.6.51/52	1792	Hardware-Sicherheitsmodul	Schlüssel der Issuing CA, Cluster über zwei Räume
Vault	vault.caas.bavd.intern → vault-0 / -1 / -2	10.30.8.7	443 → 8200, 8201	Vault 1.16.3, Raft	Namespace vault-system auf ocp-prod, je Knoten 20 GiB RWO, Unseal 3 von 5
Administration	jump01.mgmt.bavd.intern	10.99.4.10	22	RHEL 9.4	einziger Zugang zu iam-p0x und pki-p0x

3.3 Vernetzung und Ports

Alle Zonenübergänge sind einzeln freigegeben; Tabelle 5 ist die verbindliche Portmatrix. Änderungen erfolgen ausschließlich per Change über den Netzbetrieb (Frank Dettmer, netzbetrieb@bavd.bund.de, Durchwahl 1240). Betrieblich wichtigste Regel ist FW-ZSD-004: Über sie laufen alle ACME-Anträge der CaaS-Plattform; ihr Verlust führte 2025 zu ZSDSUP-0119 (Kapitel 7.2.1).

Tabelle 5: Portmatrix und Firewallregeln

Regel	Quelle	Ziel	Port	Zweck
FW-ZSD-001	ZONE-EXT, Arbeitsplatzclients	10.20.6.20	TCP 443	Anmeldung an allen Oberflächen (OIDC)
FW-ZSD-002	ZONE-APP-WE, Egress 10.30.9.40–43	10.20.6.20	TCP 443	Token und Discovery für dd-gateway, Grafana, Konsole
FW-ZSD-003	ZONE-VERF 10.40.22.11/12	10.20.6.20	TCP 443	Token-Endpunkt für vpp-portal und obs-vpp
FW-ZSD-004	ZONE-APP-WE, Egress 10.30.9.40–43	10.20.6.40	TCP 443	ACME und RA-Portal für cert-manager (Event-System, Mars, Plattform)
FW-ZSD-005	alle Zonen	10.20.6.45	TCP 80	OCSP-Abfrage und CRL-Abruf
FW-ZSD-006	10.20.6.21–23	10.20.6.11/12	TCP 636	Benutzerföderation und Gruppenauflösung (LDAPS)
FW-ZSD-007	10.20.6.21–23	10.20.6.31/32	TCP 5432	Keycloak- und EJBCA-Datenbank
FW-ZSD-008	10.20.6.21–23	10.20.6.21–23	TCP 7800	Infinispan-Cluster, zonenintern
FW-ZSD-009	ZONE-VERF, ZONE-APP-WE, ZONE-MGMT	10.30.8.7	TCP 443	Vault-Zugriff der Verfahren und der Automatisierung
FW-ZSD-010	Pods vault-system	10.30.8.6	TCP 6443	Kubernetes-Authentifizierung (Prüfung der ServiceAccount-Token)
FW-ZSD-011	10.20.6.41/42	10.20.6.51/52	TCP 1792	Zugriff der Issuing CA auf das Sicherheitsmodul

Regel	Quelle	Ziel	Port	Zweck
FW-ZSD-012	ZONE-MGMT (Prometheus, Checkmk)	10.20.6.21-23, .41/42	TCP 9000, 9100, 6556	Metriken, Node-Exporter, Checkmk-Agent
FW-ZSD-013	10.99.4.10	10.20.6.21-23, .41/42	TCP 22	Administration ausschließlich vom Jumphost
FW-ZSD-014	10.20.6.41/42	smtp.bavd.intern	TCP 25	Ablauf- und Sperrbenachrichtigungen der PKI
FW-ZSD-015	10.99.8.30	10.20.6.21-23, .31/32, .41/42	TCP 8403	Datensicherung über Commvault

Achtung

Nach jeder Netzwartung sind FW-ZSD-004 und FW-ZSD-005 zu prüfen. Fehlt ACME, laufen Zertifikate still ab — die Störung zeigt sich erst Wochen später beim Konsumenten. Die synthetische Prüfung (PkiAcmeProbeFailed, Kapitel 8.1) darf nicht stummgeschaltet werden.

4 Konsumenten und Verknüpfungen

Tabelle 6 ist die zentrale Verknüpfungstabelle: je Konsument der IAM-Client, das Zertifikatsverfahren, der Vault-Pfad, der Ansprechpartner und das Betriebshandbuch. Wer eine Änderung an einem dieser Objekte plant, findet hier die Gegenseite.

Tabelle 6: Konsumentenmatrix

Konsument	IAM-Client	Zertifikate	Vault-Pfad	Ansprechpartner	Dokument
VPP Portal	vpp-portal	manuell, keytool und Keystore (SOP-VPP-05)	kv/vpp/prod/*	Torben Machwitz; Heiko Brandtner (4471)	BHB-VRF-0207
Mars Dokumentendienste, dd-gateway	dd-gateway	cert-manager (Routen), manuell (Archiv-Adapter, SOP-DD-05)	kv/dd/*	Rainer Kolbe; Christina Haberland (3208)	BHB-VRF-0118
Event-System 2.0, Grafana	es-grafana	cert-manager (ACME)	kv/event-system/grafana/oidc	Miriam Falk; Tobias Reinhardt (2117)	BHB-PLT-0042
Event-System 2.0 ⇄ Kafka	kein Client (SASL/SCRAM-SHA-512)	manuell, Broker-Zertifikate durch Talwerk IT-Services	kv/event-system/kafka/scram	Jonas Brinkmann; Holger Pietsch (Talwerk)	BHB-PLT-0042
CaaS OpenShift-Konsole	caas-console	cert-manager, ClusterIssuer bawd-issuing-ca-3	kv/caas/* (Plattformgeheimnisse; der Konsolen-Client selbst nutzt keinen Pfad)	Andreas Wehrle (2140); Sonja Wiechert (2143)	BHB-PLT-0001
Checkmk und OpenSearch (VPP)	obs-vpp	manuell	kv/vpp/monitor	Torben Machwitz	BHB-VRF-0207

VPP Portal (BHB-VRF-0207)

Am Client `vpp-portal` hängt die gesamte Anmeldung des Portals (Authorization Code mit PKCE, Access-Token 5 min, Refresh-Token 30 min). Das Secret liegt in `kv/vpp/prod/oidc-client-secret` und wird vom Playbook `vpp-secrets` zur Laufzeit gelesen; eine Rotation ohne Abstimmung führt binnen Minuten zum vollständigen Anmeldeausfall (ZSDSUP-0208 / VPPSUP-2251). Zertifikate bezieht VPP ausschließlich manuell über das RA-Portal — `cert-manager` und `ACME` werden dort bewusst nicht genutzt. Rollen entstehen aus AD-Gruppen, weshalb ein Verzeichnisausfall die Anmeldung unmittelbar verhindert.

Mars Dokumentendienste (BHB-VRF-0118)

Der Client `dd-gateway` prüft die Token am einzigen Eingang; die Berechtigung je Dokument wird gegen AD-Gruppen aufgelöst. Die Dienste in `dokumentendienste-prod` holen ihre Geheimnisse über die Kubernetes-Authentifizierung ihres ServiceAccounts (Token 1 h) aus `kv/dd/*` — darunter die Kennwörter von `DD_META` und `DD_AUDIT`, die S3-Zugangsschlüssel und die Keystore-Passphrase des Archiv-Adapters (`kv/dd/tls/arch`). Ist Vault versiegelt, starten neue Pods nicht; sichtbar zuerst am `dd-ingest-worker`, dessen Ausfall den Spool füllt. Zertifikate laufen gemischt: Routen über `ACME`, die Keystores von `dd-arch-p01`, `dd-arch-p02` und `arch-al-p01` manuell im Fenster Dienstag ab 18:00 Uhr.

Event-System 2.0 (BHB-PLT-0042)

Drei Kopplungen: Client `es-grafana` für das Ops-Cockpit, `cert-manager` für Routen und Service Mesh über `ACME`, `SASL/SCRAM`-Zugangsdaten der Konten `es-broker-receiver` und `es-broker-dispatcher` in `kv/event-system/kafka/scram`. Die Datenebene ist von der Anmeldung unabhängig — ein IAM-Ausfall kostet das Cockpit, nicht die Zustellung. Empfindlich ist das Event-System beim CA-Wechsel: Fehlt die neue Issuing-CA im Truststore

der Pods `kafka-broker-receiver` und `kafka-broker-dispatcher`, bricht die Verbindung zu den Brokern ab (ZSDSUP-0214 / ESSUP-1455).

CaaS-Plattform (BHB-PLT-0001)

Die Plattform ist Konsument und Träger zugleich: Client `caas-console` für die Konsole, ClusterIssuer `bavd-issuing-ca-3` für alle Routen- und Mesh-Zertifikate — und Namespace, Speicher und Ingress für Vault. Aus dieser Doppelrolle entsteht die zirkuläre Abhängigkeit in Kapitel 6.3. Betrieblich folgt daraus eine harte Regel: Jede Knotenwartung, die einen Vault-Knoten berührt, wird 24 Stunden vorher an `zsd@bavd.bund.de` angekündigt. Der Verstoß dagegen war die Ursache von ZSDSUP-0247 / CAASUP-0351.

Überwachung des VPP (BHB-VRF-0207)

Checkmk und die OpenSearch Dashboards des VPP melden ihre Nutzer über `obs-vpp` an; das Geheimnis liegt in `kv/vpp/monitor`, die Zertifikate werden manuell getauscht. Ein IAM-Ausfall kostet nur die Anmeldung an den Oberflächen: Messung und Alarmierung laufen weiter und erreichen die Rufbereitschaft über das SMTP-Relay.

Hinweis

Bewusst nicht angebunden: VPP nutzt weder ACME noch cert-manager und ist nicht Mandant der CaaS-Plattform; das Event-System hat keine eigene LDAPS-Verbindung zum Active Directory, Gruppen erreichen es ausschließlich über den Keycloak-Realm. Für beide Fälle existiert keine Firewallregel — ein entsprechender Antrag wäre abzulehnen.

5 Betrieb

5.1 Servicezeiten und Wartungsfenster

- **Betriebszeiten:** 24/7 mit Rufbereitschaft für IAM und Vault. **Servicezeiten:** Mo–Fr 08:00–16:30 Uhr.
- **Eigenes Wartungsfenster:** Freitag 18:00–22:00 Uhr (Keycloak-Releases, CA-Wechsel, Vault-Updates).
- **Fremde Wartungsfenster:** Änderungen, die einen Konsumenten treffen (Client-Secret, Truststore, Sperrung), werden im Fenster des *Konsumenten* ausgeführt — VPP Do 17:00–21:00, Mars Dokumentendienste Di 18:00–22:00, Event-System Mi ab 17:00, CaaS-Plattform Mo 20:00–00:00.
- **Vorlauf:** 5 Arbeitstage für Änderungen an Client oder Zertifikat, 10 Arbeitstage für CA-Wechsel und Vault-Update.
- **Meldewege:** Servicedesk 0800 1180 100, zsd@bavd.bund.de, Kanal #zsd-betrieb, Jira-Projekte ZSDSUP (Betrieb) und PKI (Zertifikatsanträge).

5.2 Zugänge und Rollen

Der Zugang zu `iam-p0x` und `pki-p0x` erfolgt ausschließlich über `jump01.mgmt.bavd.intern` mit Schlüsselverfahren und Sitzungsprotokollierung; ein Kennwortzugang existiert nicht. Vault wird über die Route und die Rolle des Kontos genutzt, nicht über einen Knotenzugang.

- **AD-Gruppen:** BAVD-ZSD-Admin (alle drei Dienste, vier Personen), BAVD-ZSD-RA (Ausstellung und Sperrung), BAVD-ZSD-Vault (Policies und Unseal), BAVD-ZSD-Lesen (Servicedesk, nur Anzeige).
- **Technische Konten:** `svc-iam-admin` (Realm-Verwaltung über `kcadm.sh`, nur vom Jump host), `svc-ra-portal`, `svc-zsd-deploy` (AppRole, Token täglich erneuert), `brk-iam-admin` (Break-Glass, Kapitel 8.3).
- **Vault-Policies:** je Mandant eine Policy mit Lesezugriff auf den eigenen Pfad (`mandant-vpp`, `mandant-dd`, `mandant-event-system`, `caas-platform`) und `zsd-admin` für den Betrieb. Schreibrecht auf einen Mandantenpfad hat nur der Mandant.
- **Vier-Augen-Prinzip:** Sperrungen, Änderungen an Root- oder Issuing-CA, Break-Glass, Vault-Policies.
- **Geheimnisse** werden nie per E-Mail oder Chat übergeben, sondern über `kv/zsd/handover/<client>` mit 24 Stunden Lebensdauer und Leserecht nur für den Empfänger.

5.3 Standardabläufe

5.3.1 Keycloak rollierend neu starten (SOP-ZSD-02)

Anlass: Konfigurationsänderung, Sicherheitsupdate, Neustart nach Speicherproblem. Auswirkung auf die Konsumenten: keine, solange mindestens zwei Knoten bedienen (Tabelle 8, Zeile 1). Dauer 25 Minuten in der Servicezeit; verantwortlich IAM-Betrieb (Kai Ostermann), Vertretung Sabine Wollmer.

1. Vorgang in ZSDSUP anlegen, in #zsd-betrieb ankündigen und prüfen, dass kein Releasewechsel eines Konsumenten läuft (VPP donnerstags, Mars dienstags, Event-System mittwochs).
2. Zustand und Clustergröße prüfen — erwartet dreimal UP und Clustergröße 3:

```
for h in iam-p01 iam-p02 iam-p03; do printf "%s " $h
  curl -sk https://$h.bavd.intern:8443/health/ready | grep -o '"status":"[A-Z]*"'; done
curl -s http://iam-p01.bavd.intern:9000/metrics | grep -E 'vendor_jgroups_cluster_size'
```

3. Knoten im Lastverteiler abmelden (Netzbetrieb, Frank Dettmer); Verbindungen laufen 30 Sekunden aus:

```
tmsl modify ltm pool iam-prod members modify { 10.20.6.21:8443 { session user-disabled } }
```

4. Dienst neu starten und Wiedereintritt in den Cluster prüfen:

```
ssh iam-p01 'sudo systemctl restart keycloak'
ssh iam-p01 'sudo journalctl -u keycloak -n 60 --no-pager | grep -Ei "ISPN000094|Keycloak .*
started"'
curl -sk https://iam-p01.bavd.intern:8443/health/ready
```

5. Knoten aufnehmen und Anmeldung mit dem Prüfkonto testen:

```
tmsh modify ltm pool iam-prod members modify { 10.20.6.21:8443 { session user-enabled } }
curl -s -d "client_id=zsd-probe" -d "grant_type=client_credentials" -d
"client_secret=$PROBE_SECRET" \
https://iam.bavd.intern/realms/bavd-intern/protocol/openid-connect/token | grep -o
'access_token'
```

6. Mindestens 10 Minuten Abstand halten, dann Knoten 2 und 3 auf demselben Weg. Der Abstand stellt sicher, dass die verteilten Caches neu ausbalanciert sind (Lehre aus ZSDSUP-0252). Zwei Knoten dürfen nie gleichzeitig neu starten — sonst verlieren die Sitzungen ihre zweite Kopie.

7. Abschließen: Clustergröße prüfen, Vorgang mit den Prüfausgaben schließen, Meldung in #zsd-betrieb.

5.3.2 Client-Secret rotieren (SOP-ZSD-03)

Anlass: Jahresrotation, Verdacht auf Kenntnisnahme, Wechsel eines Dienstleisters. Auswirkung: ohne Abstimmung vollständiger Anmeldeausfall beim Konsumenten. Der Ablauf ist **abstimmungspflichtig**; kein Schritt darf vorgezogen werden.

1. Vorgang in ZSDSUP, Client und Konsument benennen, Ansprechpartner aus Tabelle 6 informieren.
2. Termin im Wartungsfenster des Konsumenten vereinbaren und schriftlich bestätigen lassen. Ohne Bestätigung wird nicht rotiert.
3. Neues Secret erzeugen und im Übergabepfad ablegen:

```
export KC=/opt/keycloak/bin/kcadm.sh
$KC config credentials --server https://iam.bavd.intern --realm master --user svc-iam-admin
CID=$(($KC get clients -r bavd-intern -q clientId=vpp-portal --fields id --format csv --noquotes)
$KC create clients/$CID/client-secret -r bavd-intern
NEW=$(($KC get clients/$CID/client-secret -r bavd-intern --fields value --format csv --noquotes)
vault kv put kv/zsd/handover/vpp-portal value="$NEW" ttl=24h
```

4. Der Konsument übernimmt den Wert in seinen Pfad und rollt aus (beim VPP Playbook und rollierender Tomcat-Neustart, zuerst vpp-app-p02):

```
vault kv get -field=value kv/zsd/handover/vpp-portal | vault kv put kv/vpp/prod/oidc-client-
secret value=
ansible-playbook -i inventory/prod vpp-secrets.yml --limit vpp_app_prod
ssh vpp-app-p02 'sudo systemctl restart tomcat' # danach vpp-app-p01
```

5. 15 Minuten lang das Ereignisprotokoll beobachten — erwartet keine Einträge mit `invalid_client_credentials` — dann Übergabepfad löschen und Vorgang schließen:

```
$KC get events -r bavd-intern -q type=LOGIN_ERROR --fields time,clientId,error | tail -20
vault kv metadata delete kv/zsd/handover/vpp-portal
```

Achtung

Keycloak 24.0 führt je Client nur ein gültiges Secret. Zwischen Schritt 3 und dem Abschluss von Schritt 4 ist keine neue Anmeldung möglich. Genau dieses Fenster wurde am 11.05.2026 ohne Abstimmung geöffnet — Ergebnis: ZSDSUP-0208 mit Partnervorgang VPPSUP-2251, 42 Minuten Ausfall (Kapitel 7.2.2).

5.3.3 Vault entsiegeln (SOP-ZSD-05)

Anlass: Vault ist nach Neustart der Pods, Knotenwartung oder Kaltstart versiegelt. Auswirkung: neue Pods der Mandanten starten nicht, Deployments blockieren (Tabelle 8, Zeile 4). Verantwortlich Marcel Ebert (Durchwahl 1352); nötig sind drei der fünf Anteile (Tabelle 14). Der Unseal braucht weder IAM noch PKI — das ist die Auflösung der zirkulären Abhängigkeit (Kapitel 6.3).

1. Zustand feststellen — erwartet Sealed true, Schwellwert 3:

```
oc -n vault-system get pods -o wide
oc -n vault-system exec vault-0 -- vault status | grep -E 'Seal
Type|Initialized|Sealed|Threshold'
```

2. Drei Anteilshalter zusammenrufen (Rufbereitschaft über 0800 1180 100). Jeder gibt seinen Anteil selbst ein; Anteile werden nicht weitergegeben.
3. Führenden Knoten entsiegeln (dreimal, je Halter einmal), dann die Folgeknoten und den Raft-Verbund prüfen — erwartet drei Mitglieder, einer leader:

```
oc -n vault-system exec -ti vault-0 -- vault operator unseal
oc -n vault-system exec -ti vault-1 -- vault operator unseal
oc -n vault-system exec -ti vault-2 -- vault operator unseal
oc -n vault-system exec vault-0 -- vault operator raft list-peers
oc -n vault-system exec vault-0 -- vault status | grep -E 'Sealed|HA Mode'
```

4. Konsumenten anlaufen lassen (betroffen sind die während der Versiegelung neu gestarteten Pods) und die Mandanten informieren:

```
oc -n dokumentendienste-prod rollout restart deployment/dd-ingest-worker
oc -n eventing-kafka-broker rollout status statefulset/kafka-broker-dispatcher
```

5. Vorgang mit Ursache und Dauer schließen, CaaS-Plattformbetrieb (Andreas Wehrle) und betroffene Mandanten informieren.

5.4 Zertifikatslebenszyklus

Abbildung 2 zeigt den Lebenszyklus über alle Verfahren: Antrag, Ausstellung, Verteilung, Überwachung, Erneuerung oder Sperrung — mit den drei unterschiedlichen Wegen. Verbindlich sind SOP-ZSD-01 (Antrag und Sperrung) und SOP-ZSD-04 (CA-Wechsel und Truststore-Verteilung).

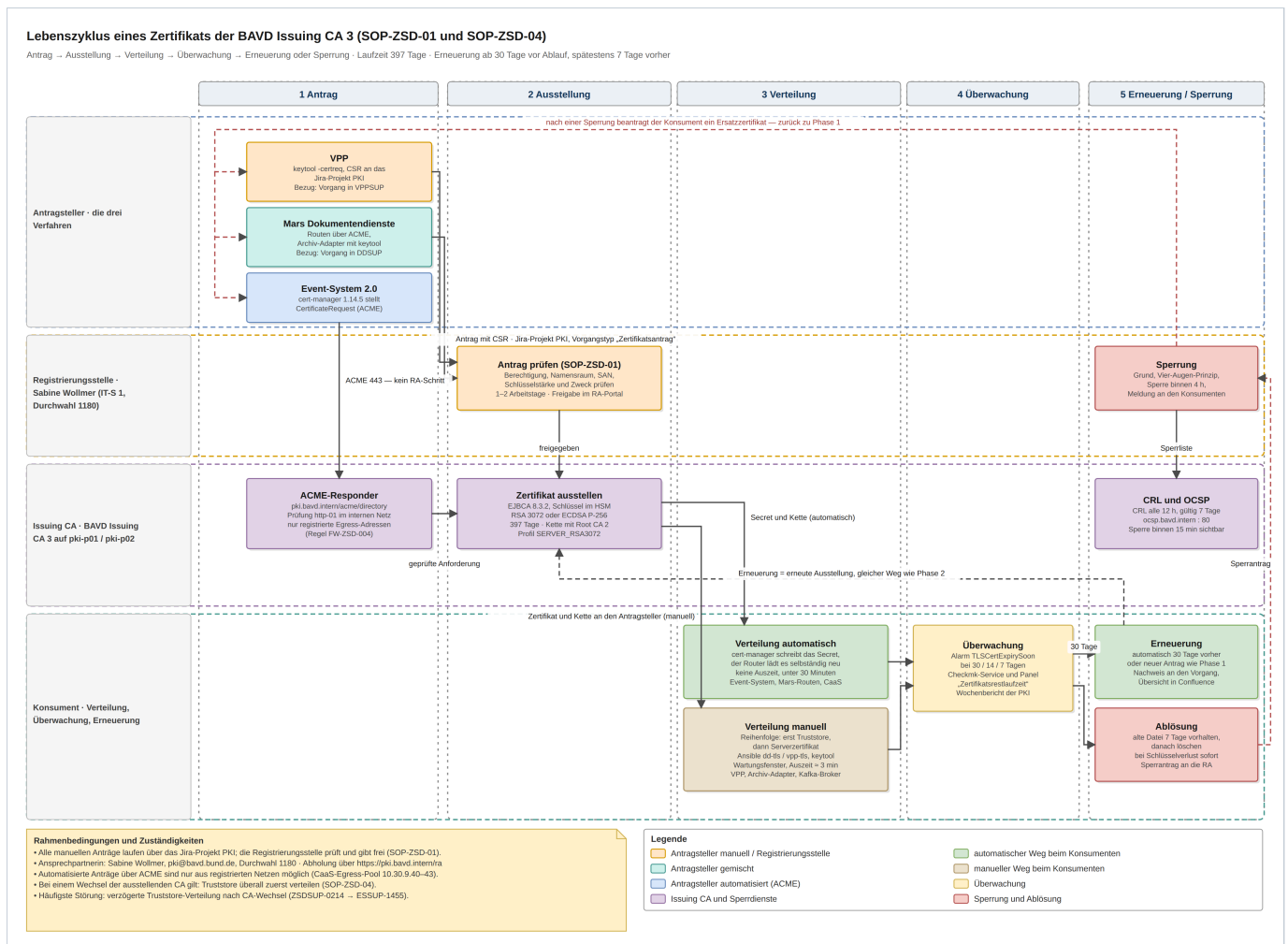


Abbildung 2: Lebenszyklus eines Zertifikats der BAVD Issuing CA 3 mit den Bahnen Antragsteller, Registrationsstelle, Issuing CA und Konsument — automatisierter Weg über ACME, gemischter Weg der Dokumentendienste, vollständig manueller Weg des VPP.

Rahmen für alle Zertifikate: Ausstellung durch die **BAVD Issuing CA 3** (2023–2033) unter der **BAVD Root CA 2** (2019–2039), Schlüssel RSA 3072 Bit oder ECDSA P-256, Laufzeit 397 Tage, Erneuerung ab 30 Tage vor Ablauf und spätestens 7 Tage vorher, Überwachung über **TLSCertExpirySoon** bei 30, 14 und 7 Tagen.

Antrag prüfen und ausstellen (Registrationsstelle, Sabine Wollmer; 1–2 Arbeitstage): Antrag im Jira-Projekt PKI, Vorgangstyp „Zertifikatsantrag“, mit CSR, Verwendungszweck, Hostnamen und Verweis auf den Vorgang des Verfahrens — im Beispiel unten der Antrag PKI-2841 zum Vorgang DDSUP-1219 der Dokumentendienste (BHB-VRF-0118). Geprüft werden Berechtigung für den Namensraum, SAN-Einträge, Schlüsselstärke und Zweck; ausgestellt wird mit dem Profil **SERVER_RSA3072**, der private Schlüssel der CA verlässt das Sicherheitsmodul nicht.

```
openssl req -in /var/ra/ingang/PKI-2841.csr -noout -text | grep -E 'Subject:|Public-Key|DNS:|IP Address'
/opt/ejbca/bin/ejbca.sh ra addentity --username dd-arch-p01 \
  --dn "CN=dd-arch-p01.dd.bavd.intern,OU=Bereich VF 3,0=BAVD,C=DE" \
  --caname "BAVD Issuing CA 3" --certprofile SERVER_RSA3072 --type 1 --token USERGENERATED
/opt/ejbca/bin/ejbca.sh ra certreq --username dd-arch-p01 \
  --csr /var/ra/ingang/PKI-2841.csr --out /var/ra/ausgang/dd-arch-p01.pem
openssl x509 -in /var/ra/ausgang/dd-arch-p01.pem -noout -subject -issuer -dates -ext subjectAltName
```

Automatisierter Weg (ACME): Für Mandanten der CaaS-Plattform entfällt der Antrag. cert-manager stellt die Anforderung selbst, der Responder prüft mit http-01 im internen Netz und gibt frei, sofern die Quelladresse zum Egress-Pool 10.30.9.40–43 gehört; die Verteilung übernimmt der Router ohne Auszeit.


```
curl -s https://pki.bavd.intern/acme/directory | head -5
/opt/ejbca/bin/acme-stat.sh --last 24h          # erwartet 40-60 Anfragen je Tag
```

Sperrung: Anträge nimmt die Registrierungsstelle im Vier-Augen-Prinzip an; die Sperre ist binnen vier Stunden wirksam und binnen 15 Minuten in CRL und OSCP sichtbar. Danach beantragt der Konsument ein Ersatzzertifikat wie in Phase 1.

```
/opt/ejbca/bin/ejbca.sh ra revokecert --dn "CN=dd-arch-p01.dd.bavd.intern,O=BAVD,C=DE" \
--serial 4f1c9a2b7d3e --reason keyCompromise
/opt/ejbca/bin/ejbca.sh ca createcrl --caname "BAVD Issuing CA 3"
openssl ocp -issuer /etc/pki/BAVD-Issuing-CA-3.pem -serial 0x4f1c9a2b7d3e \
-url http://ocsp.bavd.intern -resp_text | grep -E 'Cert Status|Revocation'
```

CA-Wechsel (SOP-ZSD-04): feste Reihenfolge — erst die neue CA in *allen* Truststores verteilen, dann Serverzertifikate tauschen. Während der Umstellung sind beide CA-Zertifikate parallel vorzuhalten. Die Freigabe zum Tausch erteilt die Registrierungsstelle erst, wenn jeder Mandant den Erhalt bestätigt hat (Bestätigungsliste im Vorgang, Vorlauf 10 Arbeitstage). Diese Reihenfolge ist die Lehre aus ZSDSUP-0214.

5.5 Standard Operating Procedures

Tabelle 7 nennt alle sechs Verfahren mit Auslöser, Verantwortung, Dauer und Abstimmungspflicht.

Tabelle 7: Standard Operating Procedures

SOP	Titel	Auslöser	Verantwortlich	Dauer	Abstimmung
SOP-ZSD-01	Zertifikatsantrag bearbeiten, ausstellen, sperren	Vorgang im Projekt PKI, Sperrantrag	Sabine Wollmer	1–2 Arbeitstage	bei Sperrung Vier-Augen-Prinzip
SOP-ZSD-02	Keycloak-Release und rollierender Neustart	Update, Konfigurationsänderung	Kai Ostermann	25 min / 2 h (Release)	nur Ankündigung
SOP-ZSD-03	Client-Secret rotieren	Jahresplan, Verdacht auf Kenntnisnahme	Kai Ostermann mit dem Konsumenten	45 min im Fenster des Konsumenten	ja, verbindlich
SOP-ZSD-04	CA-Wechsel und Truststore-Verteilung	Ablauf oder Wechsel einer CA	Sabine Wollmer mit allen Mandanten	10 Arbeitstage Vorlauf	ja, mit Bestätigungsliste
SOP-ZSD-05	Vault-Unseal und Break-Glass	Vault versiegelt, Verlust des Root-Tokens	Marcel Ebert, drei Anteilshalter	20 min ab Erreichbarkeit	Meldung an CaaS und Mandanten
SOP-ZSD-06	Kaltstart der Sicherheitsdienste	Notfall, Stromabschaltung, Wiederanlauf	Kai Ostermann	90 min bis Schritt 7	Reihenfolge nach SOP-CAAS-06

6 Abhängigkeiten und Auswirkungen

6.1 Überblick

Abbildung 3 fasst zusammen, was ein Neustart oder Ausfall je Dienst bei den vier Konsumenten bewirkt, und zeigt die zirkuläre Abhängigkeit samt Auflösung.

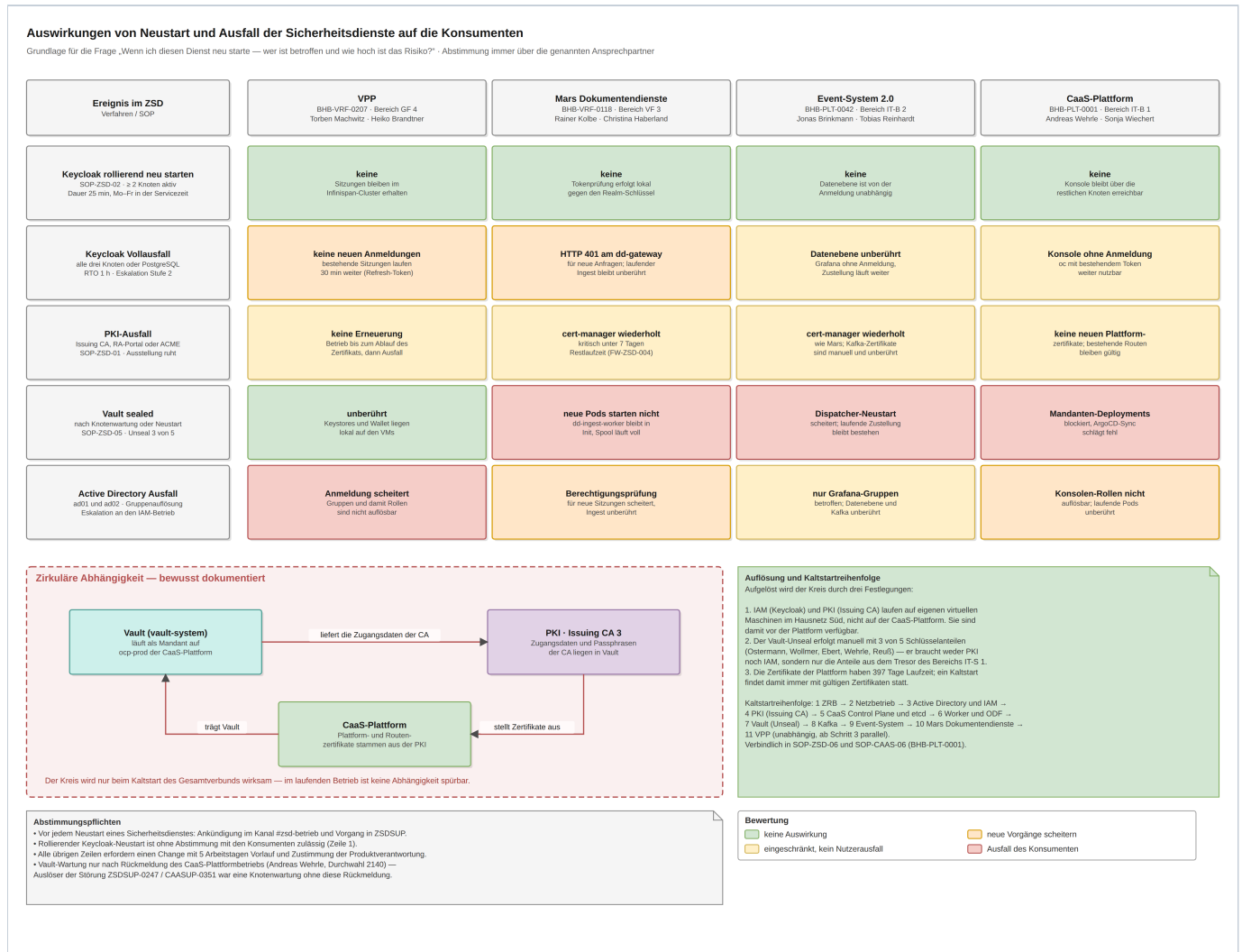


Abbildung 3: Auswirkungsmatrix der fünf Ereignisse auf VPP, Mars Dokumentendienste, Event-System 2.0 und CaaS-Plattform, dazu die zirkuläre Abhängigkeit und die Kaltstartreihenfolge des Gesamtverbunds.

6.2 Auswirkungsmatrix

Tabelle 8 ist die verbindliche Fassung und wird vor jedem Change gelesen: Zeile gleich Ereignis, Spalte gleich Konsument, Feld gleich Auswirkung. Ansprechpartner je Spalte nennt Tabelle 6.

Tabelle 8: Auswirkungen bei Neustart oder Ausfall

Ereignis	VPP (BHB-VRF-0207)	Mars Dokumentendienste (BHB-VRF-0118)	Event-System 2.0 (BHB-PLT-0042)	CaaS-Plattform (BHB-PLT-0001)
Keycloak rollierend, mindestens 2 Knoten aktiv	keine	keine	keine	keine

Ereignis	VPP (BHB-VRF-0207)	Mars Dokumentendienste (BHB-VRF-0118)	Event-System 2.0 (BHB-PLT-0042)	CaaS-Plattform (BHB-PLT-0001)
Keycloak Vollausfall	keine neuen Anmeldungen, bestehende Sitzungen laufen 30 Minuten weiter	dd-gateway antwortet auf neue Anfragen mit HTTP 401, laufender Ingest unberührt	Datenebene unberührt, Grafana ohne Anmeldung	Konsole ohne Anmeldung, oc mit bestehendem Token nutzbar
PKI-Ausfall (Issuing CA, RA-Portal oder ACME)	keine Erneuerung möglich, Betrieb bis zum Ablauf des Zertifikats	cert-manager wiederholt, kritisch unter 7 Tagen Restlaufzeit	wie Mars Dokumentendienste; Kafka-Zertifikate sind manuell und unberührt	keine neuen Plattformzertifikate, bestehende Routen bleiben gültig
Vault versiegelt	unberührt, Keystores und Wallet liegen lokal auf den Knoten	neue Pods starten nicht (dd-ingest-worker), der Spool läuft voll	Neustart des Dispatchers scheitert, laufende Zustellung bleibt bestehen	Mandanten-Deployments blockiert, ArgoCD-Sync schlägt fehl
Active Directory Ausfall	Gruppenauflösung fehlt, Anmeldung scheitert	Berechtigungsprüfung für neue Sitzungen scheitert, Ingest unberührt	nur Grafana-Gruppen betroffen	Konsolen-Rollen nicht auflösbar

Daraus folgen drei Planungsregeln: Ein rollierender Keycloak-Neustart ist ohne Abstimmung zulässig und nur anzukündigen. Jede Maßnahme, die Vault versiegelt oder das Verzeichnis betrifft, ist ein Change mit fünf Arbeitstagen Vorlauf und Zustimmung der betroffenen Produktverantwortung. Maßnahmen an der PKI sind für den laufenden Betrieb unkritisch, aber terminkritisch für Zertifikate mit weniger als sieben Tagen Restlaufzeit — die Liste dazu liefert `TLSCertExpirySoon`.

6.3 Zirkuläre Abhängigkeit und ihre Auflösung

Bewusst dokumentiert: **Vault** läuft auf der **CaaS-Plattform**, deren Zertifikate von der **PKI** stammen, deren Zugangsdaten und Passphrasen in **Vault** liegen. Im laufenden Betrieb ist der Ring nicht spürbar; wirksam wird er nur beim Kaltstart. Aufgelöst wird er durch drei Festlegungen:

1. IAM und PKI laufen auf eigenen virtuellen Maschinen im Hausnetz Süd, nicht auf der CaaS-Plattform, und sind damit vor der Plattform verfügbar.
2. Der Vault-Unseal erfolgt manuell mit drei von fünf Anteilen (Tabelle 14) und benötigt weder PKI noch IAM, sondern nur die Anteile aus dem Tresor des Bereichs IT-S 1.
3. Alle Plattformzertifikate haben 397 Tage Laufzeit; ein Kaltstart findet damit immer mit gültigen Zertifikaten statt. Nur ein Kaltstart mit abgelaufenem Zertifikat erfordert eine Notausstellung (Break-Glass, Kapitel 8.3).

Die Kaltstartreihenfolge ist in SOP-CAAS-06 (BHB-PLT-0001) verbindlich und in SOP-ZSD-06 für die Sicherheitsdienste ausgeführt: 1 ZRB (Virtualisierung, Speicher, Netzhardware) → 2 Netzbetrieb (Firewall, Lastverteiler) → 3 Active Directory und IAM → 4 PKI (Issuing CA) → 5 CaaS Control Plane und etcd → 6 CaaS Worker und ODF → 7 Vault (Unseal) → 8 Kafka (Talwerk IT-Services) → 9 Event-System 2.0 → 10 Mars Dokumentendienste → 11 VPP (unabhängig, ab Schritt 3 parallel). Für die Schritte 3, 4 und 7 ist der Bereich IT-S 1 verantwortlich, das Zeitbudget bis Schritt 7 beträgt 180 Minuten.

Gut zu wissen

VPP hängt an Schritt 3, nicht an Schritt 7: Weil die Keystores lokal auf den Knoten liegen und das Portal nicht Mandant der Plattform ist, kann VPP unmittelbar nach Verzeichnis und IAM anlaufen — auch dann, wenn Vault noch versiegelt ist.

7 Troubleshooting

7.1 Meldewege und erste Prüfungen

Störungen erreichen den ZSD-Betrieb über den Servicedesk (0800 1180 100), zsd@bavd.bund.de oder #zsd-betrieb; bei Sev-1 in der Produktion wird außerhalb der Servicezeit die Rufbereitschaft für IAM und Vault gerufen. Die Einordnung folgt immer derselben Frage: Betrifft die Meldung *neue* Anmeldungen, *neue* Pods oder *neue* Zertifikate? Laufende Sitzungen, laufende Pods und gültige Zertifikate sind von Störungen der Sicherheitsdienste in der Regel nicht betroffen. Drei Prüfungen vorab:

```
curl -sk https://iam.bavd.intern/realms/bavd-intern/.well-known/openid-configuration | head -3
curl -s -o /dev/null -w '%{http_code}\n' https://pki.bavd.intern/acme/directory
oc -n vault-system exec vault-0 -- vault status | grep -E 'Sealed|HA Mode'
```

7.2 Dokumentierte Störungsbilder

7.2.1 ACME-Anträge werden von der Firewall verworfen

Vorgang ZSDSUP-0119 · **Partnervorgang** DDSUP-0794 · **Klasse** Sev-2 · 18.08.2025

Umgebung. Produktion, ACME-Endpunkt <https://pki.bavd.intern/acme/directory> auf `pki-p01` und `pki-p02`, Antragsteller `cert-manager 1.14` auf `ocp-prod` (Egress 10.30.9.40–43), Regel FW-ZSD-004.

Fehlerbeschreibung. Nach einer Netzwartung erreichte kein ACME-Antrag mehr die PKI. Auf ZSD-Seite war das nur als Ausbleiben von Anfragen sichtbar, nicht als Fehler; drei Tage später lief das Routenzertifikat der Dokumentendienste ab und die Recherche war nicht erreichbar (DDSUP-0794, 1 Stunde 40 Minuten).

```
// pki-p01: /var/log/ejbca/acme.log
2025-08-18 21:58:44 INFO [acme] order created account=cert-manager-ocp-prod id=8841
2025-08-18 22:14:03 INFO [acme] Anfragen letzte 60 min: 0 (Erwartung 2-4)
// Firewall FW-WE-01, Verwurfsprotokoll
2025-08-19 06:02:11 deny 10.30.9.40 -> 10.20.6.40:443 proto TCP rule=default-deny if=vlan220
// Gegenseite (Mars Dokumentendienste), cert-manager
E0821 05:11:37 acme: error creating new order: Post "https://pki.bavd.intern/acme/new-order":
dial tcp 10.20.6.40:443: i/o timeout
```

Lösung. Der Netzbetrieb (Frank Dettmer) hat FW-ZSD-004 dauerhaft freigeschaltet und in die Prüfliste nach Netzwartungen aufgenommen; die Dokumentendienste haben das Routenzertifikat mit `cmctl renew` erneuert (35 Minuten nach Erkennung).

Hauptursache. Die Regel war Teil eines temporären Regelwerks der Netzwartung und wurde nicht wiederhergestellt. Unentdeckt blieb das drei Tage, weil das Ausbleiben von Anträgen nicht überwacht war.

Nachbildung. In der Testumgebung die Regel auf `pki-t01` schließen und aus einem Pod `curl -v https://pki.bavd.intern/acme/directory` aufrufen; nach 30 Sekunden erscheint der Zeitüberschreitungsfehler im Protokoll des `cert-managers`.

Prozessänderung. Synthetische ACME-Prüfung alle 15 Minuten (`PKIAcmeProbeFailed`) und Zahl der ACME-Anträge im Wochenbericht der PKI. Die Regeln FW-ZSD-004 und FW-DD-014 sind in beiden Handbüchern als Voraussetzung benannt.

7.2.2 Client-Secret ohne Abstimmung rotiert

Vorgang ZSDSUP-0208 · **Partnervorgang** VPPSUP-2251 · **Klasse** Sev-1 · 11.05.2026

Umgebung. Produktion, Realm `bavd-intern`, Client `vpp-portal` (confidential, Authorization Code mit PKCE), Konsument `vpp-app-p01` und `vpp-app-p02` (Release 1.2.3, Tomcat 10.1.24).

Fehlerbeschreibung. Am Abend des 11.05.2026 wurde das Secret im Rahmen der Jahresrotation erneuert, ohne den Termin mit dem Systembetrieb VPP abzustimmen. Am Morgen des 12.05.2026 schlug jede Anmeldung fehl; der Health-Endpoint des Portals antwortete weiter, weshalb kein Alarm des Verfahrens auslöste und die Meldung über den First Level kam.

```
// IAM, Ereignisprotokoll des Realms bavd-intern
2026-05-12 08:41:07 WARN [org.keycloak.events] type=LOGIN_ERROR, realmId=bavd-intern,
  clientId=vpp-portal, ipAddress=10.40.22.11, error=invalid_client_credentials
... 214 gleichartige Ereignisse in 12 Minuten
// Gegenseite (VPP), vpp-app.log
org.springframework.security.oauth2.client.resource.OAuth2AccessDeniedException:
  Error requesting access token.
Caused by: HttpClientErrorException$Unauthorized: 401 Unauthorized on POST
  "https://iam.bavd.intern/realms/bavd-intern/protocol/openid-connect/token":
  {"error":"invalid_client","error_description":"Invalid client or Invalid client credentials"}
```

Lösung. Das aktuelle Secret wurde über `kv/zsd/handover/vpp-portal` bereitgestellt, vom Systembetrieb VPP nach `kv/vpp/prod/oidc-client-secret` übernommen, mit `vpp-secrets` ausgerollt und der Apptier rollierend neu gestartet (zuerst `vpp-app-p02`). Gesamtdauer 42 Minuten.

Hauptursache. Ein rotiertes Secret wirkt sofort und ohne Überlappung — Keycloak 24.0 führt je Client nur ein gültiges Secret. Der ausgerollte Wert im Konsumenten war damit augenblicklich falsch.

Nachbildung. In der Abnahme für `vpp-portal` ein neues Secret erzeugen, das Playbook bewusst nicht ausführen und `https://vpp-abnahme.bavd.intern` aufrufen; der Fehler tritt beim Token-Tausch auf und erscheint im Ereignisprotokoll als `invalid_client_credentials`.

Prozessänderung. SOP-ZSD-03 ist seit Version 2.1 abstimmungspflichtig: Termin im Fenster des Konsumenten, schriftliche Bestätigung, Übergabe nur über `kv/zsd/handover/<client>` (24 h), Erfolgsprüfung im Ereignisprotokoll. Die Rotation aller produktiven Clients folgt einem Jahresplan, der mit den Wartungsfenstern der Verfahren abgeglichen ist.

7.2.3 Truststore nach CA-Wechsel zu spät verteilt

Vorgang ZSDSUP-0214 · **Partnervorgang** ESSUP-1455 (Verteilauftrag), Folgestörung ESSUP-1517 · **Klasse** Sev-1 · 13.05.2026

Umgebung. Produktion, Wechsel der ausstellenden CA für die Kafka-Verbindung des Event-System; betroffen die Truststores der Pods `kafka-broker-receiver` und `kafka-broker-dispatcher` im Namespace `eventing-kafka-broker` sowie die Broker `kafka-p01` bis `kafka-p03` im Hausnetz Süd.

Fehlerbeschreibung. Der Verteilauftrag (ESSUP-1455) lag seit dem 28.04.2026 vor. Die Verteilung an die Container verzögerte sich, während die Broker-Zertifikate im Wartungsfenster am 14.05.2026 bereits getauscht wurden; die Zustellung blieb stehen (ESSUP-1517, 42 Minuten).

```
// Event-System, kafka-broker-dispatcher
2026-05-14 09:12:44 ERROR [kafka-producer-network-thread] o.a.k.c.NetworkClient
  javax.net.ssl.SSLHandshakeException: PKIX path building failed:
  unable to find valid certification path to requested target
// ZSD, Prüfung des verteilten Truststores
$ oc -n eventing-kafka-broker exec statefulset/kafka-broker-dispatcher -- \
  keytool -list -keystore /etc/kafka/truststore.p12 -storetype PKCS12 | grep -c issuing-ca
1      // erwartet 2: alte und neue Issuing-CA während der Umstellung
```

Lösung. Truststore mit beiden CA-Zertifikaten neu verteilt, Pods versetzt neu gestartet; eine Nachsendung war nicht nötig, weil Kafka die Ereignisse gehalten hat.

Hauptursache. Verletzte Reihenfolge: Serverzertifikate wurden getauscht, bevor die neue ausstellende CA überall im Truststore vorhanden war.

Nachbildung. In der Testumgebung ein Broker-Zertifikat der Test-CA ausstellen, den Truststore der Dispatcher-Pods unverändert lassen und ein Ereignis einstellen; der Handshake bricht mit PKIX path building failed ab.

Prozessänderung. SOP-ZSD-04 schreibt fest: Truststore zuerst, Freigabe zum Tausch erst nach Rückmeldung aller Mandanten (Bestätigungsliste im Vorgang), Vorlauf 10 Arbeitstage, beide CA-Zertifikate parallel. Auf der Gegenseite ist die Vorbedingung in SOP-6 des Event-System (BHB-PLT-0042) aufgenommen.

7.2.4 Vault nach Knotenwartung versiegelt

Vorgang ZSDSUP-0247 · **Partnervorgang** CAASUP-0351, Folgevorgang beim Mandanten DDSUP-1201 · **Klasse** Sev-1 · 02.07.2026

Umgebung. Produktion, Vault 1.16.3 im Namespace `vault-system` auf `ocp-prod`, drei Knoten mit Raft-Speicher, Schwelle 3 von 5. Betroffene Mandanten: Mars Dokumentendienste und Event-System.

Fehlerbeschreibung. Bei einer Knotenwartung nach SOP-CAAS-01 wurden zwei Worker gedrainet; dabei wurden zwei der drei Vault-Pods verlagert und starteten versiegelt. Mit nur einem entsiegelten Knoten verlor der Raft-Verbund sein Quorum, der Dienst antwortete auf keine Anfrage mehr. Um 05:58 Uhr scheiterten die ersten neu startenden Pods der Dokumentendienste, gegen 06:20 Uhr blockierten die ArgoCD-Synchronisierungen der Plattform.

```
$ oc -n vault-system exec vault-1 -- vault status
Seal Type shamir | Initialized true | Sealed true | Total Shares 5 | Threshold 3 | HA Enabled true
// Mars Dokumentendienste, dd-ingest-worker
2026-07-02 05:58:12 ERROR vault-agent auth handler: error authenticating:
Error making API request. Code: 503. Errors: * Vault is sealed
2026-07-02 05:58:12 WARN pod dd-ingest-worker-7c9f4d6b8-x2ktp Init:CrashLoopBackOff
```

Lösung. Entsiegelung nach SOP-ZSD-05 mit drei Anteilen (Ostermann, Ebert, Wehrle), Neustart der betroffenen Pods, Freigabe der ArgoCD-Synchronisierung. Gesamtdauer 38 Minuten, davon 22 Minuten für das Zusammenrufen der Anteilshalter. Der Plattformbetrieb weist für denselben Vorfall 48 Minuten aus (CAASUP-0351): Dort wird ab dem Beginn der Knotenwartung bis zur vollständigen Synchronisierung aller Mandanten gemessen, hier ab der Meldung bis zur Entsiegelung.

Hauptursache. Vault hält den Hauptschlüssel nur im Arbeitsspeicher; werden alle Pods gleichzeitig neu geplant, ist der Dienst zwangsläufig versiegelt. Die Wartung war nicht mit dem ZSD-Betrieb abgestimmt, weshalb niemand auf den Unseal vorbereitet war.

Nachbildung. In der Testumgebung `oc -n vault-system-test delete pod vault-1 vault-2` ausführen; Vault startet versiegelt, ein Testpod mit Vault-Agent geht in `Init:CrashLoopBackOff`.

Prozessänderung. Knotenwartungen, die einen Vault-Knoten berühren, werden 24 Stunden vorher an `zsd@bavd.bund.de` angekündigt; der ZSD-Betrieb bestätigt die Erreichbarkeit von drei Anteilshaltern (aufgenommen in SOP-CAAS-01 und SOP-ZSD-05). Der Alarm `VaultSealed` (`vault_core_unsealed == 0`) meldet seit Juli 2026 unmittelbar an die Rufbereitschaft. Automatischer Unseal ist als offener Punkt OP-ZSD-02 vermerkt und setzt ein zweites Sicherheitsmodul voraus.

7.3 Incident-Liste

Tabelle 9 führt die Vorgänge, aus denen die heute geltenden Festlegungen entstanden sind; die Spalte „Partnervorgang“ nennt den zugehörigen Vorgang beim Konsumenten.

Tabelle 9: Incidents der Zentralen Sicherheitsdienste (Auszug)

Vorgang	Datum	Titel	Ursache	Dauer	Partnervorgang	Maßnahme
ZSDSUP-0119	18.08.2025	ACME-Anträge erreichen die PKI nicht	FW-ZSD-004 nach Netzwartung nicht wiederhergestellt	3 Tage unentdeckt	DDSUP-0794	Regel dauerhaft frei, synthetische ACME-Prüfung
ZSDSUP-0166	12.01.2026	Gruppenänderungen wirken verzögert	Replikationsverzögerung ad01 / ad02	2 h 15 min	—	Alarm AdDirectoryDegraded auf 15 min
ZSDSUP-0208	11.05.2026	Client-Secret vpp-portal ohne Abstimmung rotiert	Jahresrotation ohne Termin mit dem Konsumenten	42 min beim Konsumenten	VPPSUP-2251	SOP-ZSD-03 abstimmungspflichtig, Übergabepfad
ZSDSUP-0214	13.05.2026	Truststore-Verteilung nach CA-Wechsel verzögert	Serverzertifikate vor der Truststore-Verteilung getauscht	42 min	ESSUP-1455	SOP-ZSD-04 mit Bestätigungsliste, 10 Tage Vorlauf
ZSDSUP-0231	09.06.2026	OCSP-Antwortzeiten über 500 ms	Zwischenspeicher des Responders nach CRL-Erzeugung geleert	50 min	—	CRL-Erzeugung aus der Spitzenlast verlegt
ZSDSUP-0247	02.07.2026	Vault nach Knotenwartung versiegelt	alle drei Pods gleichzeitig neu geplant, Wartung nicht abgestimmt	38 min	CAASUP-0351, DDSUP-1201	Ankündigungspflicht 24 h, Alarm VaultSealed
ZSDSUP-0252	18.07.2026	iam-p03 nach Update nicht im Cluster	Mindestabstand beim rollierenden Neustart nicht eingehalten	18 min	—	10 min Abstand in SOP-ZSD-02 festgeschrieben

8 Monitoring, Sicherung und Notfall

8.1 Metriken, Schwellwerte und Alarme

Container-Metriken kommen aus Prometheus der CaaS-Plattform und werden im Grafana-Ordner „ZSD“ dargestellt (<https://grafana.caas.bavd.intern>); die virtuellen Maschinen überwacht Checkmk (<https://checkmk.bavd.intern>, Agent 6556, Node-Exporter 9100). Tabelle 10 nennt die betrieblich relevanten Metriken mit Schwellwert, Alarmnamen und Empfänger.

Tabelle 10: Metriken, Schwellwerte, Alarme

Metrik / Prüfung	Schwellwert	Alarm	Empfänger
vendor_jgroups_cluster_size (Keycloak, 9000)	< 3 über 5 min	IamClusterDegraded	#zsd-betrieb
Anteil LOGIN_ERROR an allen Anmeldungen	> 5 % über 10 min	IamLoginFailureRate	#zsd-betrieb, zsd@bavd.bund.de
Antwortzeit Token-Endpunkt (p95)	> 800 ms über 10 min	IamLatencyHigh	#zsd-betrieb
Erreichbarkeit /health/ready je Knoten (Checkmk)	2 Prüfungen fehlerhaft	IamNodeDown	Rufbereitschaft bei zwei Knoten
Replikationsabstand PostgreSQL / LDAPS-Antwortzeit und AD-Replikation	> 30 s / > 300 ms bzw. > 15 min	IamDatabaseLag, AddirectoryDegraded	ZSD-Betrieb, ZRB
vault_core_unsealed	== 0	VaultSealed	Rufbereitschaft, Sev-1
Raft-Mitglieder und Führung	< 3 Mitglieder oder keine Führung	VaultNoLeader	Rufbereitschaft
Restlaufzeit der Zertifikate (Checkmk-Service „TLS iam/pki“)	30 / 14 / 7 Tage	TLSCertExpirySoon	ZSD-Betrieb und Konsument
Synthetische ACME-Prüfung (alle 15 min)	2 Fehlversuche	PkiAcmeProbeFailed	#zsd-betrieb
OCSP-Antwortzeit (p95) und Fehlerquote; Alter der CRL	> 500 ms bzw. > 1 %; > 14 h	Pki0cspDegraded, PkiCrlStale	PKI-Betrieb

Protokolle liegen 30 Tage im Loki-Bestand der Plattform (Vault) und 90 Tage lokal unter `/var/log/keycloak` und `/var/log/ejbca`, gesichert über Commvault. Das Ereignisprotokoll des Realms wird 180 Tage aufbewahrt, Ausstellungs- und Sperrnachweise der PKI dauerhaft.

8.2 Sicherung und Wiederherstellung

Tabelle 11 nennt die Sicherungsobjekte und ihre Verfahren.

Tabelle 11: Sicherungsobjekte und Verfahren

Objekt	Verfahren	Turnus	Aufbewahrung
PostgreSQL keycloak und ejbca	Basissicherung, Archivierung der Transaktionsprotokolle	täglich 22:30, Protokolle alle 15 min	30 Tage Platte, 90 Tage Band
Realm-Konfiguration	<code>kc.sh export</code> in das Repository zsd-config	täglich 01:00	Git-Historie
Schlüsselmaterial der Issuing CA	im Sicherheitsmodul, verschlüsselte Anteile in versiegelten Umschlägen	bei Änderung, Prüfung jährlich	Tresor Bereich IT-S 1
Root-CA ca-root-off01	Datenträger und Schlüsselanteile, nicht vernetzt	bei Nutzung	Tresor Bereich IT-S 1
Vault (Raft-Speicher)	<code>vault operator raft snapshot save</code>	täglich 23:00, Dauer ca. 3 min	14 Tage
Unseal-Schlüsselanteile	versiegelte Umschläge, Ausgabe nur gegen Protokoll	Bestandsprüfung halbjährlich	Tresor Bereich IT-S 1

Objekt	Verfahren	Turnus	Aufbewahrung
Konfiguration der virtuellen Maschinen	Commvault-Dateisicherung, Ansible-Repository	täglich 23:30	30 Tage Platte, 90 Tage Band

IAM (RTO 1 h, RPO 15 min). Ausfall eines Knotens: Der Lastverteiler nimmt das Pool-Member binnen 15 Sekunden heraus, der Betrieb läuft mit zwei Knoten weiter; Neuaufbau über Ansible in 40 Minuten. Verlust der Datenbank: Basissicherung zurückspielen und Protokolle nachfahren (25 min), Realm gegen den Export prüfen (10 min), Anmeldeprobe (5 min). Sitzungen sind nicht Teil der Sicherung — nach einer Wiederherstellung melden sich alle Nutzer neu an.

PKI (RTO 4 h). Die Ausstellung ruht, bestehende Zertifikate bleiben gültig, daher fällt kein Verfahren aus. Reihenfolge: Datenbank zurückspielen, Anbindung an das Sicherheitsmodul prüfen, Testausstellung, CRL neu erzeugen und veröffentlichen. Die aktuelle CRL hat Vorrang vor der Wiederaufnahme der Ausstellung.

Vault. Nach Verlust des Raft-Verbunds wird die letzte Momentaufnahme zurückgespielt und anschließend entsiegelt:

```
oc -n vault-system exec -ti vault-0 -- vault operator raft snapshot restore /tmp/vault-2026-07-01.snap
oc -n vault-system exec -ti vault-0 -- vault operator unseal          # danach vault-1 und vault-2
oc -n vault-system exec vault-0 -- vault operator raft list-peers
```

Der Vault-Rückspieltest läuft halbjährlich mit den Anteilen aus dem Tresor des Bereichs IT-S 1 (letzte Durchführung 11.02.2026, bestanden), der Wiederanlaufstest des IAM quartalsweise (24.06.2026, bestanden) und der Kaltstarttest des Gesamtverbunds jährlich gemeinsam mit dem CaaS-Plattformbetrieb (15.05.2026, bestanden, Schritt 7 nach 164 Minuten erreicht).

8.3 Break-Glass

Break-Glass-Zugänge sind protokollpflichtig, nur zu zweit nutzbar und werden nach Gebrauch sofort erneuert. Die Umschläge liegen im Tresor des Bereichs IT-S 1, die Ausgabe bestätigt die Bereichsleitung (Dr. Annika Reuß, Durchwahl 1300).

- **IAM:** Notfallkonto brk-iam-admin im Realm `master`, nur lokal auf `iam-p01` gültig und ohne Verzeichnisanbindung — für den Fall, dass das Active Directory ausgefallen ist und eine Konfiguration geändert werden muss. Kennwortwechsel binnen 24 Stunden.
- **Vault:** neues Root-Token über `vault operator generate-root` mit drei Anteilen, Rücknahme mit `vault token revoke`. Ein dauerhaft gültiges Root-Token existiert nicht.
- **PKI:** Notausstellung ohne regulären Antragsweg durch Sabine Wollmer gemeinsam mit Kai Ostermann, Nachdokumentation im Projekt PKI binnen eines Arbeitstages — Anwendungsfall: Kaltstart mit abgelaufenem Plattformzertifikat.

9 Rollen, Verantwortlichkeiten und Eskalation

9.1 Rollen und Erreichbarkeit

Tabelle 12 nennt alle Rollen mit Namen, Aufgabe und Erreichbarkeit; die Ansprechpartner der Konsumenten stehen in Tabelle 6.

Tabelle 12: Rollen, Namen, Erreichbarkeit

Rolle	Name	Aufgabe	Kontakt
Verantwortlicher ZSD, IAM-Betrieb	Kai Ostermann	Keycloak, Active Directory, Clients und Rollen; Gesamtverantwortung für dieses Handbuch	iam-betrieb@bavd.bund.de, 1315
Vertretung, PKI-Betrieb und Registrierungsstelle	Sabine Wollmer	Ausstellung, Sperrung, CA-Wechsel, Truststore-Verteilung	pki@bavd.bund.de, 1180
Secret-Management	Marcel Ebert	Vault, Policies, Unseal, Momentaufnahmen	zsd@bavd.bund.de, 1352
Bereichsleitung IT-S (Eskalationsstufe 2)	Dr. Annika Reuß	Entscheidung über Break-Glass, Freigabe von Notmaßnahmen	Durchwahl 1300
Netzbetrieb	Frank Dettmer	Regeln FW-ZSD-001 ... FW-ZSD-015, Lastverteiler	netzbetrieb@bavd.bund.de, 1240
CaaS-Plattformbetrieb	Andreas Wehrle, Vertretung Sonja Wiechert	Trägerplattform von Vault, Knotenwartung, Kaltstart (SOP-CAAS-06)	caas-betrieb@bavd.bund.de, 2140
First Level	Servicedesk	Annahme, Einordnung, Weiterleitung; Leserecht über BAVD-ZSD-Lesen	0800 1180 100
Infrastrukturdienstleister	ZRB (Serviceklasse Bronze)	virtuelle Maschinen, Active Directory, Bandsicherung	über den Servicedesk

9.2 Eskalation

Die Eskalation folgt Tabelle 13; Auslöser ist immer ein Vorgang in ZSDSUP.

Tabelle 13: Eskalationsstufen

Stufe	Wer	Wann	Reaktionszeit
1	Servicedesk und ZSD-Betrieb (Bereitschaft IAM und Vault)	jede Störungsmeldung	30 min in der Servicezeit, 60 min außerhalb
2	Dr. Annika Reuß, Bereichsleitung IT-S	Sev-1 über 2 Stunden, Break-Glass, Sperrung eines produktiven Zertifikats	60 min
3	Krisenstab nach NFH-ITS-1.4	Ausfall von zwei der drei Dienste, Verdacht auf Kompromittierung der CA	sofort

Bei Verdacht auf Kompromittierung des Schlüsselmaterials der Issuing CA gilt keine Reaktionszeit, sondern eine feste Reihenfolge: Ausstellung sofort anhalten, Bereichsleitung und Informationssicherheit informieren, betroffene Zertifikate sperren, CRL veröffentlichen — erst danach die Ursache klären.

9.3 Halter der Unseal-Schlüsselanteile

Vault ist mit fünf Anteilen und der Schwelle drei initialisiert. Kein Halter besitzt mehr als einen Anteil, Anteile werden nie weitergegeben (Kapitel 5.3.3). Die Verteilung über drei Ablagen in zwei Bereichen ist beabsichtigt: Die drei Anteile für den Regelfall liegen im Tresor des Bereichs IT-S 1 und werden nur im Vier-Augen-Prinzip entnommen; ist dieser Tresor oder der Bereich nicht erreichbar, genügen die Anteile 4 und 5 zusammen mit einem der ersten

drei. Ein Unseal ist damit auch bei Ausfall einer Ablage möglich, ohne dass eine einzelne Person die Schwelle erreichen kann. Tabelle 14 ist bei jedem Personalwechsel fortzuschreiben.

Tabelle 14: Halter der fünf Unseal-Schlüsselanteile (Schwelle 3 von 5)

Anteil	Halter	Rolle	Ablage
1	Kai Ostermann	IAM-Betrieb, Bereich IT-S 1 (1315)	versiegelter Umschlag, Tresor IT-S 1
2	Sabine Wollmer	PKI-Betrieb, Registrierungsstelle (1180)	versiegelter Umschlag, Tresor IT-S 1
3	Marcel Ebert	Secret-Management (1352)	versiegelter Umschlag, Tresor IT-S 1
4	Andreas Wehrle	Teamleiter CaaS-Plattformbetrieb (2140)	versiegelter Umschlag, Tresor Bereich IT-B 1
5	Dr. Annika Reuß	Bereichsleitung IT-S (1300)	versiegelter Umschlag, Tresor der Bereichsleitung

10 Glossar und verwandte Dokumente

10.1 Glossar

ACME

Protokoll zur automatischen Beantragung und Erneuerung von Zertifikaten; Endpunkt `https://pki.bavd.intern/acme/directory`, genutzt von `cert-manager` auf der CaaS-Plattform.

AppRole

Authentifizierung in Vault für Automatisierung ohne Kubernetes-Kontext, zum Beispiel `svc-vpp-deploy` für die Ansible-Playbooks des VPP.

Break-Glass

Notfallzugang, der die regulären Kontrollen umgeht: nur zu zweit, protokollpflichtig, mit sofortiger Erneuerung des Geheimnisses (Kapitel 8.3).

cert-manager

Erweiterung der CaaS-Plattform (1.14.5), die Zertifikate über ACME automatisch beantragt und erneuert; ClusterIssuer `bavd-issuing-ca-3`.

Client (IAM)

Registrierte Anwendung im Realm, etwa `vpp-portal` oder `dd-gateway`; ein vertraulicher Client weist sich mit einem Client-Secret aus.

CRL

Sperrliste der ausstellenden CA: alle 12 Stunden erzeugt, 7 Tage gültig, abrufbar über den Verteilpunkt `ocsp.bavd.intern`.

Infinispan

Verteilter Zwischenspeicher von Keycloak (JGroups, TCP 7800). Hält Sitzungen mit zwei Eigentümern, sodass der Ausfall eines Knotens ohne Wirkung bleibt.

Issuing CA

Ausstellende Zwischeninstanz **BAVD Issuing CA 3** (2023–2033) unter der **BAVD Root CA 2** (2019–2039); stellt alle internen Zertifikate mit 397 Tagen Laufzeit aus.

KV v2

Versionierter Schlüssel-Wert-Speicher in Vault; alle Pfade beginnen mit `kv/`, gefolgt vom Mandanten.

OCSP

Online-Abfrage des Sperrstatus eines einzelnen Zertifikats gegen `http://ocsp.bavd.intern`; Antworten sind signiert, daher ohne TLS.

OIDC

OpenID Connect, Anmeldeverfahren aller Oberflächen. Der Realm stellt Token aus, die der Konsument mit dem öffentlichen Realm-Schlüssel selbst prüft.

PKCE

Erweiterung des Authorization Code Flow, die den Codetausch an einen zusätzlichen Nachweis bindet; für `vpp-portal` verpflichtend.

Raft

Verfahren, mit dem die drei Vault-Knoten ihren Datenbestand abstimmen und einen führenden Knoten bestimmen (Port 8201).

Realm

Mandant in Keycloak; produktiv `bavd-intern`, der Realm `master` dient ausschließlich der Verwaltung.

Registrierungsstelle (RA)

Stelle, die Zertifikatsanträge prüft und freigibt, ohne selbst auszustellen; im BAVD besetzt durch Sabine Wollmer, Bereich IT-S 1.

SAN

Alternative Namen im Zertifikat. Alle Namen, unter denen ein Dienst erreichbar ist, müssen enthalten sein, sonst schlägt die Prüfung der Gegenseite fehl.

Sealed / Unseal

Zustand von Vault: Versiegelt ist der Datenbestand unlesbar; das Entsiegeln erfordert drei von fünf Schlüsselanteilen und erfolgt ausschließlich manuell.

Truststore

Ablage der vertrauenswürdigen CA-Zertifikate in einem Dienst. Bei einem CA-Wechsel wird der Truststore vor den Serverzertifikaten verteilt (SOP-ZSD-04).

10.2 Weiterführende Dokumente und Seiten

Tabelle 15 nennt die weiterführenden Quellen; die Handbücher der Konsumenten stehen mit Kennung und Stand in Tabelle 2.

Tabelle 15: Weiterführende Dokumente, Seiten und Werkzeuge

Bezeichnung	Ort	Inhalt
Betriebshandbücher der Konsumenten	BHB-VRF-0207, BHB-VRF-0118, BHB-PLT-0042, BHB-PLT-0001	Gegenseite jeder Kopplung (Tabelle 2 und 6)
Clientübersicht des Realms	confluence.bavd.intern/display/ZSD/Clients	alle 38 Clients mit Konsument, Ansprechpartner, Rotationsdatum
Zertifikats- und Vault-Übersicht	confluence.bavd.intern/display/ZSD/Zertifikate bzw. /Vault-Pfade	Bestand, Ablaufdaten, Weg (ACME oder manuell); 152 Pfade mit Policy und Wechselturnus
Repository der Konfiguration	git.bavd.intern/zsd-config	Realm-Export, Vault-Policies, Ansible-Rollen, Prüfjobs
Jira, Chat, Dashboards	jira.bavd.intern (ZSDSUP, PKI) · chat.bavd.intern/bavd/channels/zsd-betrieb · grafana.caas.bavd.intern (Ordner „ZSD“) · checkmk.bavd.intern	Vorgänge, Zertifikatsanträge, Ankündigungen, Kennzahlen und Alarmer